線上餐廳訂位系統
角色需求技術分析

針對「會員限時登入」與「後台管理登入」兩大核心需求，從安全性、權限控管到使用者體驗，全面解析推薦技術方案。

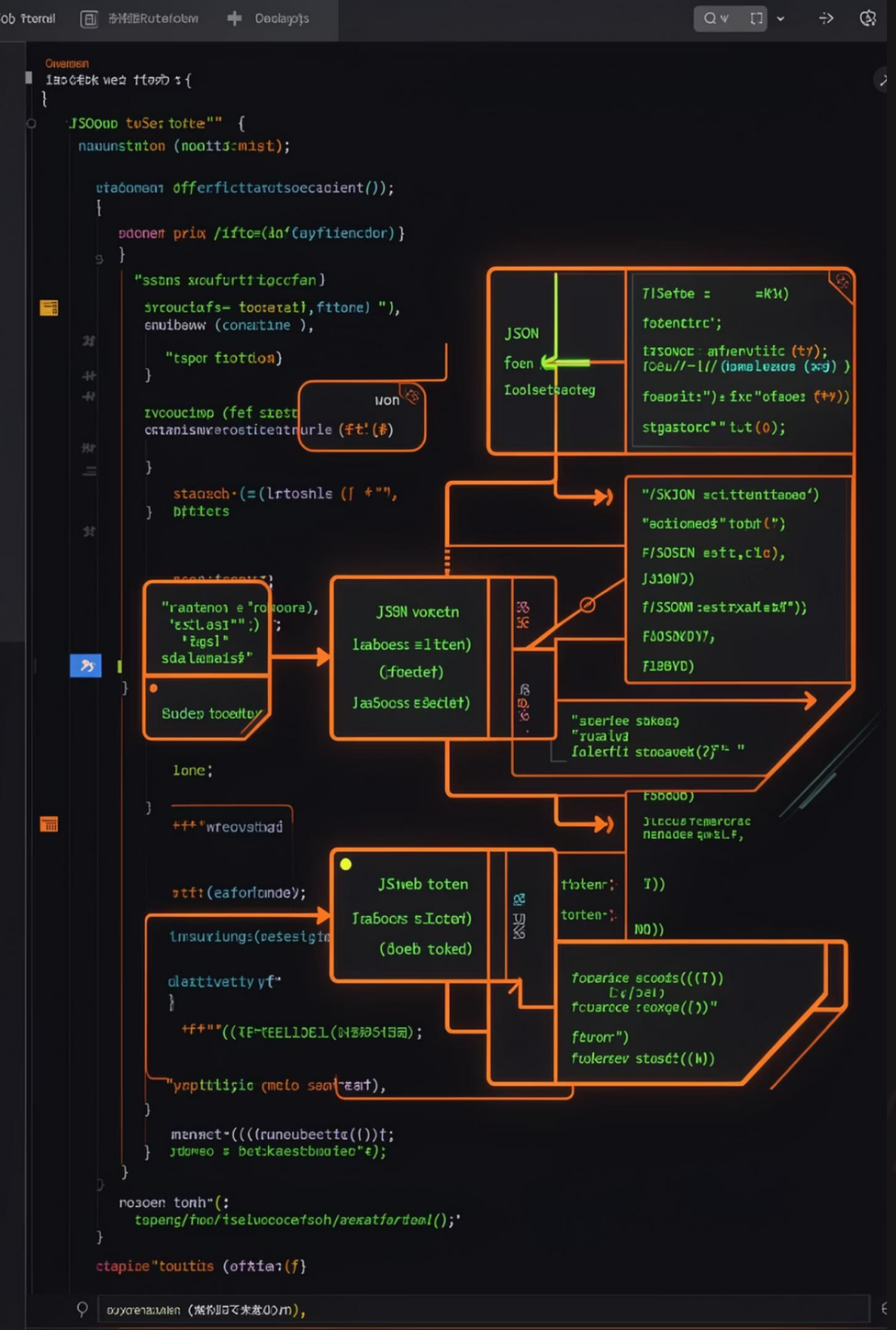
系統架構　安全設計　權限控管

需求一

會員登入限時 2 小時

精確控制登入效期，核心在於 Token 的生命週期管理，兼顧安全性與會員使用體驗。

登入成功後啟動雙重機制：後端 JWT 設定 120 分鐘失效，前端同步倒數計時，時間到自動登出並清空憑證。



JWT 效期控管與 Redis 黑名單

Expiration Time (exp)

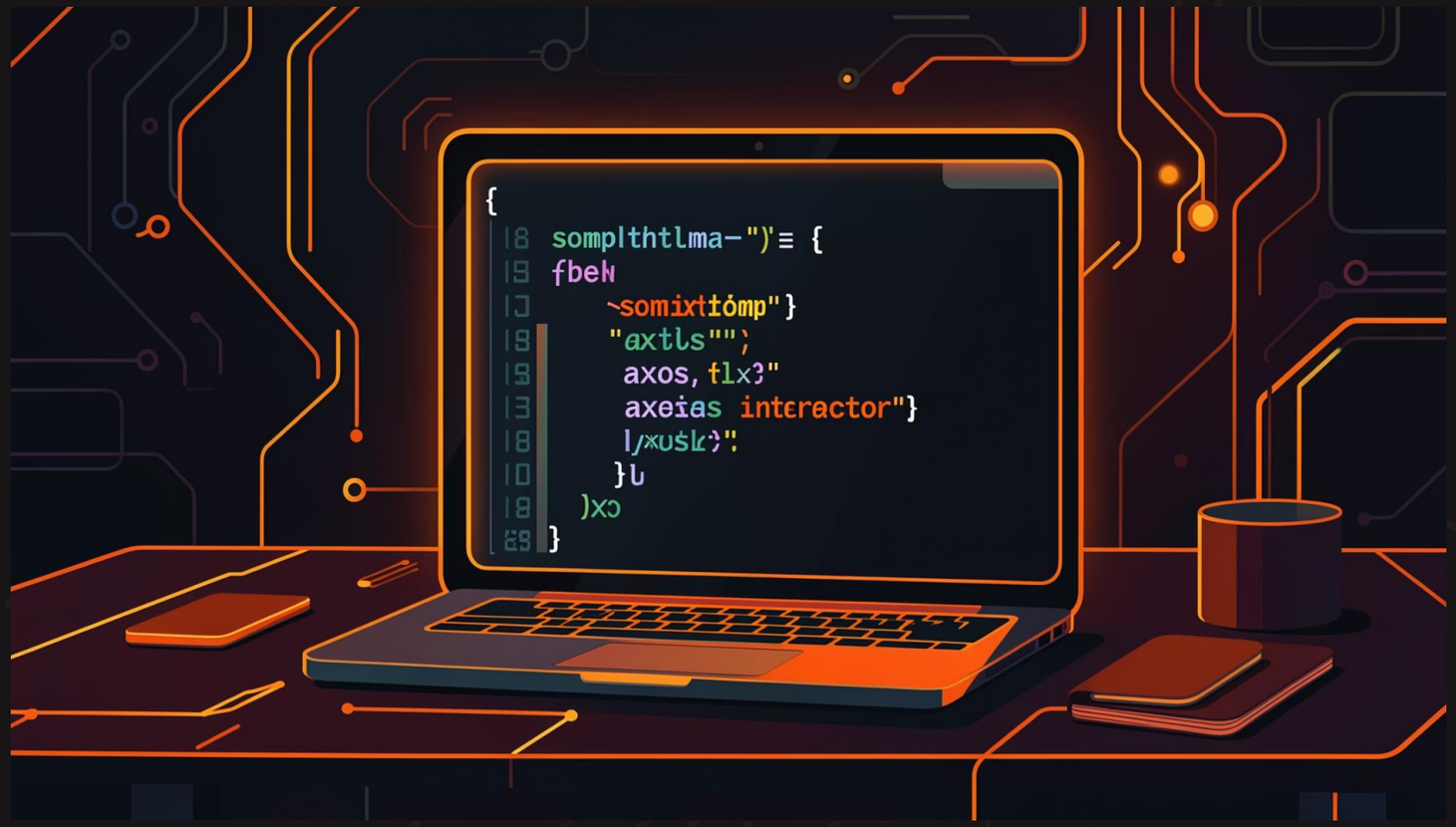
簽發 JWT 時於 Payload 加入 `exp` 欄位，設定為「當前時間 + 120 分鐘」，伺服器依系統時間自動判定失效。

Redis 黑名單（進階）

偵測異常登入時，將該 Token 存入 Redis 並設定 120 分鐘 TTL，實現強制登出。

前端實作

自動登出與 AJAX 攔截



setTimeout 計時器

登入成功後啟動 `7,200,000` 毫秒計時器，時間到彈出提示並清空 `localStorage` / `sessionStorage`。

AJAX Interceptor 統一攔截

使用 Axios 或 jQuery 統一處理回應，當後端回傳 401 時，立即導向至 `login.html`，確保所有過期請求皆被攔截。

需求二

後台人員登入：安全與權限

後台涉及營運數據與菜單修改，**安全性與稽核（Audit）**為第一優先。

RBAC 權限控管

建立 Users / Roles / Permissions 三張表，搭配 `@PreAuthorize("hasRole('ADMIN')")` 確保後端 API 攔截非法請求。

BCrypt + MFA 雙重保護

密碼以 BCrypt 不可逆雜湊儲存；登入需輸入 Google Authenticator 六位數動態碼，防止帳號盜用。

IP 白名單

後端 Filter 檢查請求 IP，限制後台僅能從餐廳內部網路環境登入，阻絕外部威脅。

Spring AOP 稽核日誌

以 AOP 攔截所有後台修改操作，紀錄「誰、何時、修改了什麼、前後差異」，以備查驗。

技術方案總覽

五大核心技術對照

以下配置在「會員便利性」與「管理安全性」之間取得最佳平衡，建議依系統規模分階段導入。

> ⓘ 優先導入 JWT + RBAC，再依需求逐步加入 Redis 黑名單、MFA 與 AOP 稽核。

需求維度	推薦技術	目的
時間控制	JWT exp 屬性	嚴格執行 120 分鐘失效
密碼安全	BCryptPasswordEncoder	防止資料庫外洩導致密碼被破解
權限控管	Spring Security / RBAC	區分管理員與一般員工權限
操作紀錄	Spring AOP + Logback	紀錄後台人員的一舉一動